BULACAN STATE UNIVERSITY

SARMIENTO CAMPUS • CITY OF SAN JOSE DEL MONTE, BULACAN

DEPARTMENT OF INFORMATION TECHNOLOGY

IT 403P: INFORMATION ASSURANCE AND SECURITY

Academic Year 2026–2027 | First Semester

CAPSTONE SECURITY POLICY WRITING ACTIVITY

CAPSTONE SECURITY POLICY PACKAGE

Security Policies and Governance

LabSync: An IoT-Based IT Laboratory Availability and Equipment Monitoring System

Governing Framework: NIST Cybersecurity Framework (CSF) 2.0 Alignment

Course & Activity	IT 403P • Capstone Security Policy Writing (Security Policies and Governance)
Author / Student	**Andrei A. Gabito**
Capstone Group & Section	**Group 3 (G03) • BSIT 4E2**
Target System	LabSync Laboratory Availability, Equipment Monitoring, and Key Tracking System
Institutional Scope	BulSU Sarmiento Campus IT Laboratories (Building 2, Rooms 201–206, 303–304)
Document Version	Version 1.3 • Academic Submission
Proposed Effectivity Date	November 1, 2026 (Subject to institutional approval)
Submission Date	October 2026

POLICY 1: ACCOUNT LIFECYCLE, AUTHENTICATION, AND ROLE-BASED PRIVILEGE MANAGEMENT

Policy Specification Parameter	Policy Details
Policy Title	Account Lifecycle, Authentication, and Role-Based Privilege Management Policy
Policy Version	Version 1.3 (Academic Submission)
Proposed Effectivity Date	November 1, 2026 (Subject to institutional approval)
Policy Owner	MIS Staff (Operational Lead)
Approving Role	IT Department Head
Target Components	`routes/auth.routes.js`, `routes/mis.routes.js`, `routes/ojt.routes.js`, `routes/faculty.routes.js`, `middleware/auth.js`
Addressed Risks	**R3** (Session Hijacking), **R5** (Audit Trail Truncation), **R11** (Administrative Role Boundary Blur)

Part 1 — Policy Identity and Purpose

The purpose of this policy is to restrict access to LabSync administrative, academic, and maintenance modules strictly to authorized personnel according to the principle of least privilege, enforce uniform session termination across shared laboratory workstations, guarantee cryptographic credential protection, and eliminate audit trail fragmentation caused by permanent account deletion. This policy aligns with the **NIST Cybersecurity Framework (CSF) 2.0** functions *GOVERN (GV.PO-01)*, *PROTECT (PR.AA-01, PR.AA-02)*, and *IDENTIFY (ID.AM-03)*.

Part 2 — Scope and Context

- **System Components Covered:** User authentication, password hashing, password reset workflows, session serialization, database role verification, account provisioning, role updates, and account deactivation in `routes/auth.routes.js`, `routes/mis.routes.js`, `routes/ojt.routes.js`, `routes/faculty.routes.js`, and `middleware/auth.js`.
- **Users and Roles Covered:** IT Department Head (`IT_DEPT_HEAD_EXCLUSIVE_ROLES`), Program Coordinator (`IT_HEAD_ROLES`), MIS Staff (`MIS_STAFF_ROLES`), Faculty (`KEY_TRANSFER_ROLES`), and On-the-Job Trainees (`OJT_ROLES`).
- **Information Covered:** User profile records, bcrypt password hashes (`$2b$12$...`), session state identifiers (`connect.sid`), and password recovery hashes.
- **Exclusions & Assumptions:** Does not govern unauthenticated public student PC reporting (governed by Policy 2) or IoT microcontroller tokens (governed by Policy 4). Assumes the application executes behind an edge reverse proxy terminating TLS 1.3.

Part 3 — Risk Basis

1. Risk R3 — Administrative Session Hijacking on Unattended Workstations:

- *Asset:* Administrative and Faculty active sessions.
- *Threat:* Opportunistic unauthorized access on shared campus laboratory workstations.
- *Weakness:* `middleware/auth.js:24` exempts `rememberMe` sessions from the 10-minute inactivity timeout.
- *Consequence:* An unauthorized user can perform administrative actions without entering credentials.
- *Existing Safeguards:* 10-minute idle logout for non-remembered sessions; live MySQL role check on every request.
- *Ratings:* Likelihood = Medium, Impact = High, Priority = **HIGH**.
- *Rating Rationale:* Laboratory PCs are shared by hundreds of students daily; persistent sessions create an immediate opening for account hijacking.
- *Linked Clauses:* Clause 1.3, Clause 1.6.

2. Risk R5 — Historical Audit Trail Truncation via Faculty Account Deletion:

- *Asset:* Key custody logs (`occupancy_log`) and maintenance records (`maintenance`).
- *Threat:* Administrative deletion of former faculty members.
- *Weakness:* `routes/faculty.routes.js:11` permits permanent SQL `DELETE`, setting `User_ID = NULL` in dependent tables.
- *Consequence:* Historical key checkouts and repair reports lose foreign-key association with instructors.
- *Existing Safeguards:* Hard deletion blocked for MIS Staff and OJT accounts; active IT Head protected.
- *Ratings:* Likelihood = Medium, Impact = Medium, Priority = **MEDIUM**.
- *Rating Rationale:* Instructor turnover is routine, and cascading `NULL` updates degrade accountability.
- *Linked Clauses:* Clause 1.5.

3. Risk R11 — Administrative Role Boundary Blur & Unauthorized Privilege Elevation:

- *Asset:* Administrative configuration routes, user provisioning, and key approval workflows.
- *Threat:* Privilege elevation through inappropriate role elevation or overly broad route access.
- *Weakness:* Shared administration between IT Head and Program Coordinator requires explicit role boundaries.
- *Consequence:* Secondary key approvals or core role modifications performed by non-executive staff.
- *Existing Safeguards:* Code-level separation of `IT_DEPT_HEAD_EXCLUSIVE_ROLES` from `IT_HEAD_ROLES` in `middleware/auth.js:8-9`.
- *Ratings:* Likelihood = Low, Impact = High, Priority = **MEDIUM**.
- *Rating Rationale:* Route middleware enforces checks, but institutional policy must govern role creation and tier separation.
- *Linked Clauses:* Clause 1.2, Clause 1.4.

Part 4 — Mandatory Policy Clauses

1. **Clause 1.1 — Cryptographic Password Storage Standard:** The application backend must hash all user passwords using `bcrypt` with a minimum work factor of 12 salt rounds (`BCRYPT_SALT_ROUNDS = 12`) prior to database insertion. Plaintext passwords must never be stored, logged, transmitted, or serialized.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `services/authService.js:21-25` ; `repositories/user.repository.js:48`).
2. **Clause 1.2 — Role-Based Administrative Boundaries:** Administrative permissions must strictly follow established role tiers. Only the IT Department Head shall approve secondary key requests or export official Room Status PDF reports. Program Coordinators may manage academic schedules and provision MIS Staff accounts, but are strictly excluded from secondary key approvals. MIS Staff manage physical keys and supervise OJT accounts. OJT Trainees are restricted to viewing schedules and updating ticket statuses.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `middleware/auth.js:8-16` ; `routes/keys.routes.js:38` ; `routes/mis.routes.js:47-55` ; `routes/ojt.routes.js:26` ; Test Executed: `tests/test-mis-authorization-gaps.js`).
3. **Clause 1.3 — Universal Session Inactivity Expiration:** Every authenticated web session must terminate automatically after exactly 10 minutes of user inactivity (`INACTIVITY_TIMEOUT_MS = 600000`). To prevent session hijacking on shared laboratory computers, the `rememberMe` idle timeout exemption in `middleware/auth.js:24` must be removed in production code.
   Implementation Status: **PARTIALLY IMPLEMENTED** (Static Inspection: 10-minute idle check active in `middleware/auth.js:20-50` ; `rememberMe` exemption requires removal; Test Executed: `tests/test-mis-authorization-gaps.js`).
4. **Clause 1.4 — Automated OJT Account Lifecycle Enforcement:** Every provisioned OJT account must possess an authoritative expiration date (`users.OJT_End_Date`). The application must re-verify this date on every privileged request using `isOjtExpired()` . As soon as the server date exceeds the end date, sessions must be terminated immediately with HTTP 401 `OJT_EXPIRED` .
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `middleware/auth.js:98-105` ; `services/authService.js:55-77` ; Test Executed: `tests/test-mis-authorization-gaps.js`).
5. **Clause 1.5 — Universal Prohibition of Permanent Account Deletion:** Permanent deletion of user accounts via SQL `DELETE` is prohibited across all user tiers. Account offboarding must be executed solely by setting `users.Status = 'DEACTIVATED'` . The existing `DELETE /api/faculty/:userId` route must be refactored to status deactivation to prevent cascading `NULL` updates in audit and maintenance records.
   Implementation Status: **PARTIALLY IMPLEMENTED** (Static Inspection: Deactivation enforced for MIS Staff and OJT; requires refactoring on Faculty routes in `routes/faculty.routes.js:11`).
6. **Clause 1.6 — Authoritative Live State Re-Verification:** The application must re-query the MySQL database on every privileged request within `requireRole()` . If an account is marked `Status = 'DEACTIVATED'` , the server must immediately destroy the session, clear the session cookie, and return HTTP 401 `ACCOUNT_DEACTIVATED` .
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `middleware/auth.js:80-96` ; Test Executed: `tests/test-mis-authorization-gaps.js`).

Part 5 — Roles and Enforcement

- **Policy Approver:** IT Department Head.
- **Technical Implementer:** MIS Staff (Operational Lead).
- **Awareness & Communication:** MIS Staff must brief all newly onboarded faculty and OJT trainees on session security during orientation.
- **Compliance Monitoring:** MIS Staff must review the user directory monthly to confirm that expired OJT accounts are deactivated.
- **Violation Handling:** Suspected policy violations, unauthorized access attempts (logged under `MIS_ACCESS_DENIED`), or credential sharing must be documented and referred to the IT Department Head for review under applicable university policies. Disciplinary action must follow established institutional procedures.
- **Exceptions:** Temporary privilege extensions must be submitted in writing and require formal approval by the IT Department Head.

POLICY 2: STUDENT IDENTITY CAPTURE, PRIVACY PROTECTION, AND PC MAINTENANCE REPORTING

Policy Specification Parameter	Policy Details
Policy Title	Student Identity Capture, Privacy Protection, and PC Maintenance Reporting Policy
Policy Version	Version 1.3 (Academic Submission)
Proposed Effectivity Date	November 1, 2026 (Subject to institutional approval)
Policy Owner	MIS Staff (Laboratory Maintenance In-Charge)
Approving Role	IT Department Head
Target Components	`routes/maintenance.routes.js` , `services/studentVerificationService.js` , `repositories/maintenance.repository.js`
Addressed Risks	**R4** (Student Data Exposure), **R9** (Public Ticket Flooding), **R12** (Workstation Identity & Token Replay)

Part 1 — Policy Identity and Purpose

The purpose of this policy is to provide an unauthenticated, friction-free fault reporting workflow for students on laboratory workstations while guaranteeing that student personal data is handled with appropriate access control and privacy protections, preventing report replay attacks, and eliminating internal exposure of student identification numbers. This policy aligns with **NIST CSF 2.0** functions *PROTECT (PR.DS-01, PR.DS-02, PR.AA-05)* and *IDENTIFY (ID.AM-02)*.

Part 2 — Scope and Context

- **System Components Covered:** Student ID QR scanning, capture token generation, workstation binding, submission throttling, report status transitions, and ticket resolution attribution in `routes/maintenance.routes.js`, `services/studentVerificationService.js`, and `repositories/maintenance.repository.js`.
- **Users and Roles Covered:** Students / Public Laboratory Visitors, OJT Technicians, MIS Staff, Faculty, and IT Department Head.
- **Information Covered:** Student Full Names, BulSU Student Numbers, PC hardware numbers, laboratory room numbers, component fault categories, and student remarks.
- **Exclusions & Assumptions:** Applies to fault reports submitted via `submit-pc-report.html`. Assumes student ID QR codes are data-bearing text representations (barcodes or JSON strings) rather than cryptographic public-key credentials. Legal classification of personal data is subject to confirmation by the university Data Protection Officer (DPO).

Part 3 — Risk Basis

1. Risk R4 — Internal Student Identifier Exposure Across Non-Admin Roles:

- *Asset:* Student Names, University Student Numbers.
- *Threat:* Authenticated non-administrative users viewing or harvesting personal data.
- *Weakness:* `routes/maintenance.routes.js:17` returns unmasked student numbers to all roles via `GET /api/reports`.
- *Consequence:* Bulk exposure of student identification numbers across faculty and student intern accounts.
- *Existing Safeguards:* Ephemeral HMAC capture tokens; database-backed student cooldowns.
- *Ratings:* Likelihood = High, Impact = Medium, Priority = **HIGH**.
- *Rating Rationale:* Any logged-in OJT intern or faculty member can view all student numbers via the network tab.
- *Linked Clauses:* Clause 2.4.

2. Risk R9 — Public Ticket Flooding & Denial of Maintenance Service:

- *Asset:* PC maintenance queue and laboratory technician availability.
- *Threat:* Malicious script submitting hundreds of falsified PC hardware tickets.
- *Weakness:* Public availability of reporting endpoints without login requirement.
- *Consequence:* Legitimate hardware issues buried under spam tickets; automated notification spam.
- *Existing Safeguards:* Multi-tiered IP rate limits; per-PC cooldown; 30-minute student number cooldown.
- *Ratings:* Likelihood = Low, Impact = Medium, Priority = **LOW**.
- *Rating Rationale:* Multi-tiered rate limits and database-backed cooldowns are currently active in code.
- *Linked Clauses:* Clause 2.3, Clause 2.5.

3. Risk R12 — Workstation Binding Manipulation, Session Token Replay & Fallback Secret Exposure:

- *Asset:* Workstation condition integrity (`lab_units.Condition_Status`) and student verification token authenticity.
- *Threat:* Re-submitting an intercepted student QR token from an offsite browser or forging HMAC capture tokens using default secrets.
- *Weakness:* Decoupled web forms risk token replay if lacking server-side nonce state. In development configurations, `config/app.config.js:13` defaults `SESSION_SECRET` to `'labsync-secret-key-change-in-production'`, which `services/studentVerificationService.js:25, 30` imports for HMAC signing (with a secondary fallback `'labsync-student-identity-capture-secret-2026'`). If run outside production, tokens could be forged using this default. However, when correctly configured (`NODE_ENV === 'production'`), `validateProductionConfig()` (`server.js:31` ; `config/app.config.js:83-85`) strictly halts startup if secrets are missing or default.
- *Consequence:* Workstation maintenance statuses manipulated without physical presence; unauthorized or forged hardware fault reports injected into the queue.
- *Existing Safeguards:* 10-minute token expiration (`TOKEN_TTL_MS = 600000`); strict workstation Room and PC binding; atomic single-use nonce consumption in ACID transactions (`student_verification_sessions`); fail-fast production startup validation.
- *Ratings:* Likelihood = Low, Impact = Medium, Priority = **LOW**.
- *Rating Rationale:* When production mode is correctly configured, fail-fast validation guarantees that missing or default secrets prevent startup; 10-minute TTL, room/PC binding, and atomic nonce invalidation mitigate token replay.
- *Linked Clauses:* Clause 2.1, Clause 2.2.

Part 4 — Mandatory Policy Clauses

1. **Clause 2.1 — Ephemeral Student ID Token Integrity & Workstation Binding:** Scanning a physical BulSU student ID card must generate a server-side signed HMAC SHA-256 capture token binding the extracted Student Name and Student Number strictly to the physical Room Number and PC Number scanned, valid for 10 minutes (`TOKEN_TTL_MS = 600000`). The HMAC verifies server token integrity and workstation binding; it does not cryptographically authenticate the physical student card itself. The service imports `SESSION_SECRET` from `config/app.config.js:13`. In production deployments (`NODE_ENV=production`), `validateProductionConfig()` halts startup if `SESSION_SECRET` is unset or default, ensuring a secure runtime secret is enforced.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `services/studentVerificationService.js:228-270` ; `config/app.config.js:83-85` ; `server.js:31`).
2. **Clause 2.2 — Atomic Replay Defense & Database Nonce Invalidation:** Every verification token must contain a 16-byte random cryptographic nonce recorded in `student_verification_sessions`. Upon report submission, the database must atomically record `Used_At = NOW()` within an ACID transaction. Any subsequent submission attempt using a consumed token must be rejected with HTTP 400 stating "*Student ID verification session has already been used*".
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `services/studentVerificationService.js:368-372` ; `database/migrations/022_create_student_verification_sessions.sql`).

3. **Clause 2.3 — Tiered Anti-Spam Rate Limiting Architecture:** The application backend must enforce multi-layered request throttling across public reporting endpoints: maximum 60 ID verifications per 10 minutes per IP (`studentVerifyLimiter`), maximum 5 report submissions per 10 minutes per IP (`publicPCReportLimiter`), and a 1-minute cooldown per IP + Room + PC combination (`pcDuplicateReportLimiter`).
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `middleware/rateLimiter.js:80-132` ; `routes/maintenance.routes.js:13-15`).
4. **Clause 2.4 — Student Number Privacy Protection and Role-Based Masking:** Student identification numbers and full names constitute personal data requiring appropriate access control. The `GET /api/reports` endpoint must inspect the caller's session role: IT Department Head and MIS Staff shall view full student numbers for administrative verification; Faculty and OJT Trainee responses must mask student numbers (e.g., `2023-****-01`) to prevent internal data harvesting.
   Implementation Status: **PROPOSED POLICY CONTROL** (Static Inspection: Currently returns unmasked student numbers to all roles in `repositories/maintenance.repository.js:127` ; requires masking logic in service tier).
5. **Clause 2.5 — Authoritative Student Cooldown Enforcement:** To prevent denial of service through rotating IP addresses, the system must enforce a 30-minute submission cooldown keyed directly to the student number in MySQL (`student_report_cooldowns`). Re-submissions within 30 minutes must be rejected with HTTP 429 indicating remaining seconds.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `repositories/maintenance.repository.js:628-669` ; `database/migrations/027_create_student_report_cooldowns.sql`).
6. **Clause 2.6 — Maintenance Report Deletion and Resolution Accountability:** Only `TICKET_DELETE_ROLES` (IT Department Head and MIS Staff) are authorized to delete maintenance reports. Resolving an issue must record the authenticated technician's user ID, role, and timestamp in `maintenance_issues.Resolved_By_User_ID` . Deletion attribution is preserved by logging an audit event in `audit_logs` under the exact action `TICKET_DELETE` .
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `routes/maintenance.routes.js:19-20` ; `controllers/maintenance.controller.js:204-210` ; `repositories/maintenance.repository.js:147, 172-175`).

Part 5 — Roles and Enforcement

- **Policy Approver:** IT Department Head.
- **Technical Implementer:** MIS Staff (Laboratory Maintenance In-Charge).
- **Awareness & Communication:** A privacy advisory must appear on `submit-pc-report.html` explaining that student numbers are captured solely for repair verification under university policy.
- **Compliance Monitoring:** MIS Staff must review open tickets weekly to ensure repair attribution is documented.
- **Violation Handling:** Suspected report falsification or ticket abuse must be documented and referred to the IT Department Head for review under applicable university policies. Any disciplinary action must follow established institutional procedures.
- **Exceptions:** Manual paper-based fault reporting is permitted during total network outages, subject to post-restoration logging by MIS Staff.

POLICY 3: PHYSICAL LABORATORY KEY ACCOUNTABILITY, CUSTODY TRANSFER, AND ANTI-TAMPER

Policy Specification Parameter	Policy Details
Policy Title	Physical Laboratory Key Accountability, Custody Transfer, and Anti-Tamper Policy
Policy Version	Version 1.3 (Academic Submission)
Proposed Effectivity Date	November 1, 2026 (Subject to institutional approval)
Policy Owner	MIS Staff (Key Custodian)
Approving Role	IT Department Head
Target Components	`routes/keys.routes.js` , `services/iot/occupancy.service.js` , `LabSync_ESP32/LabSync_ESP32.ino`
Addressed Risks	**R6** (Uncalibrated Sensing Slots), **R7** (No Mechanical Lock), **R8** (Unrecorded Peer Handoffs)

Part 1 — Policy Identity and Purpose

The purpose of this policy is to maintain an unbroken, verifiable chain of custody over physical IT laboratory keys, govern peer-to-peer faculty key handoffs, restrict secondary key loans exclusively to department-head approval, enforce physical tamper alerting at key docks, and establish clear operational boundaries for analog key sensing. This policy aligns with **NIST CSF 2.0** functions *PROTECT (PR.PS-01)*, *DETECT (DE.CM-01)*, and *RESPOND (RS.MA-01)*.

Part 2 — Scope and Context

- **System Components Covered:** Physical key slot sensing, analog multiplexer reading, buzzer alarming, faculty QR authorization, peer-to-peer custody handoffs, secondary key approvals, and physical audit logging in `routes/keys.routes.js` and `LabSync_ESP32.ino` .
- **Users and Roles Covered:** Faculty, IT Department Head, MIS Staff, and physical ESP32 Key Box hardware.
- **Information Covered:** Physical key inventory IDs, QR tag tokens, room availability states (`laboratories.Key_Status`), and occupancy log records (`occupancy_log`).
- **Exclusions & Assumptions:** The physical key dock monitors presence via analog resistor voltage dividers; it **does NOT contain solenoid locks or physical locking mechanisms** that mechanically prevent key extraction. Active automated sensing is currently operational for Rooms 203 and 204 only; slots for Rooms 201, 202, 205, 206, 303, and 304 are planned slots pending calibration.

Part 3 — Risk Basis

1. **Risk R7 — Physical Key Extraction Without Mechanical Locking Solenoids:**
   - *Asset:* Physical laboratory keys and facility security.
   - *Threat:* An individual pulling a laboratory key from the dock without prior web authorization.
   - *Weakness:* The key dock frame is an open physical monitoring slot system without mechanical solenoids or physical latches.
   - *Consequence:* The dock cannot physically lock keys in place; it can only detect removal and sound an audible alarm for calibrated slots.
   - *Existing Safeguards:* Active piezo buzzer alarm (GPIO25) and NVS incident latching for calibrated slots (Rooms 203 and 204); audit event dispatch.
   - *Ratings:* Likelihood = Medium, Impact = High, Priority = **HIGH**.
   - *Rating Rationale:* Because keys can be physically pulled at any time, immediate audible alarming and rapid incident logging are the primary deterrents.
   - *Linked Clauses:* Clause 3.1, Clause 3.4.

2. **Risk R6 — Key Misattribution & Alarm Failure in Uncalibrated Slots:**
   - *Asset:* Laboratory key inventory and real-time room availability status.
   - *Threat:* Keys placed in or pulled from uncalibrated dock slots fail to update state or trigger alarms.
   - *Weakness:* Resistor voltage calibration in `LabSync_ESP32.ino:871-896` is implemented for Rooms 203 and 204 only; the remaining six rooms evaluate to `KEY_NONE`.
   - *Consequence:* Physical key movements for Rooms 201, 202, 205, 206, 303, and 304 are not tracked, and unauthorized removals from these slots do not trigger automated alarms.
   - *Existing Safeguards:* 16-sample ADC averaging and 40ms debounce active on calibrated slots (Rooms 203 and 204).
   - *Ratings:* Likelihood = Medium, Impact = Medium, Priority = **MEDIUM**.
   - *Rating Rationale:* While 8-channel multiplexer hardware exists, firmware only calibrates 2 rooms; relying on uncalibrated slots creates silent tracking failures.
   - *Linked Clauses:* Clause 3.4, Clause 3.5.

3. **Risk R8 — Chain-of-Custody Loss via Unregistered Peer Transfers:**
   - *Asset:* Chain of custody accountability records (`occupancy_log`).
   - *Threat:* Instructor A handing a laboratory key directly to Instructor B without logging the transaction.
   - *Weakness:* Informal faculty handoffs in hallways between consecutive class periods during hurried class changeovers.
   - *Consequence:* Inability to identify responsible personnel if equipment is damaged or missing during a subsequent class.
   - *Existing Safeguards:* `POST /api/keys/transfer` endpoint requiring recipient QR scan (`routes/keys.routes.js:19`).
   - *Ratings:* Likelihood = Medium, Impact = Medium, Priority = **MEDIUM**.
   - *Rating Rationale:* Routine human behavior in high-traffic corridors makes direct handoffs common; post-facto reminders cannot prevent unregistered transfers.
   - *Linked Clauses:* Clause 3.3.

Part 4 — Mandatory Policy Clauses

1. **Clause 3.1 — Mandatory Authorized Retrieval Standard:** Physical laboratory keys must be retrieved from the dock only after presenting an authorized faculty QR code. An instructor may withdraw only the key assigned to their scheduled class period. For calibrated slots (Rooms 203 and 204), unauthorized physical removal triggers an audible alarm and tamper event; however, because the dock lacks mechanical locking solenoids, it cannot physically lock keys in place. Uncalibrated rooms (201, 202, 205, 206, 303, and 304) must be managed through manual key custody procedures.
   Implementation Status: **PARTIALLY IMPLEMENTED** (Static Inspection: QR authorization verified in `routes/keys.routes.js:16`; hardware extraction sensing operational for Rooms 203 and 204 only).

2. **Clause 3.2 — Department Head Exclusive Approval for Secondary Keys:** Faculty requiring simultaneous custody of a second laboratory key must submit a formal request via `POST /api/keys/request-additional`. Approval authority is restricted exclusively to the IT Department Head. The system rejects key-claim attempts for secondary keys unless an approved record exists in MySQL.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `routes/keys.routes.js:37-41`; `controllers/key-authorization.controller.js:50`; Test Executed: `tests/test-mis-authorization-gaps.js`).

3. **Clause 3.3 — Mandatory Registration of Peer Key Transfers:** When laboratory custody is transferred directly between instructors without returning the key to the dock, the receiving instructor must immediately scan the physical key QR tag and execute `POST /api/keys/transfer`. Key custody legally remains assigned to the original borrower until the transfer commits in MySQL.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `routes/keys.routes.js:19`; `controllers/keys.controller.js:80`).

4. **Clause 3.4 — Audible Alarming and Security Incident Latching:** The physical key dock monitors key presence via analog resistor voltage dividers and **does not contain mechanical locking solenoids or latches**; it detects and alarms upon extraction but cannot physically block key removal. For currently calibrated and supported slots (**Rooms 203 and 204**), unauthorized physical key withdrawal without prior web QR authorization immediately triggers the onboard active piezo buzzer (GPIO25), displays an unauthorized alert on the LCD, dispatches an `Unauthorized Removal` device telemetry alert (`keyEvent: 'Unauthorized Removal'`), which the backend records under audit action `IOT_UNAUTHORIZED_KEY_REMOVAL` and occupancy method `UNAUTHORIZED`, and latches the alarm in Non-Volatile Storage (NVS). The remaining six planned slots (Rooms 201, 202, 205, 206, 303, and 304) cannot reliably trigger extraction alarms until their resistor dividers are calibrated and verified. Power loss silences the physical buzzer, but upon reboot, firmware inspects NVS and resumes alarming for latched incidents.
   Implementation Status: **PARTIALLY IMPLEMENTED** (Static Inspection & Physical Verification: Calibrated and verified for Rooms 203 & 204 in `LabSync_ESP32.ino:715-728, 871-896`; remaining six rooms evaluate to `KEY_NONE` pending calibration).

5. **Clause 3.5 — Active Operational Scope & Hardware Calibration Boundary:** Automated key sensing is restricted strictly to currently calibrated slots (Rooms 203 and 204). Slots 201, 202, 205, 206, 303, and 304 represent planned expansion and must be designated as "Pending Hardware Calibration" in system documentation. Until voltage thresholds are measured and programmed into `detectKeyType()`, keys for these six rooms must be issued and logged manually by MIS Staff.
   Implementation Status: **PARTIALLY IMPLEMENTED** (Static Inspection: `LabSync_ESP32.ino:871-896` actively calibrates Rooms 203 and 204; remaining six slots evaluate to `KEY_NONE`).
6. **Clause 3.6 — Daily Physical Key Reconciliation Audit:** At the close of daily campus operations (8:00 PM), MIS Staff must inspect the physical key dock against the live LabSync dashboard. Any key marked "Absent" without an active class schedule or authorized reservation must be flagged as "MISSING", initiating immediate administrative inquiry.
   Implementation Status: **PROPOSED POLICY CONTROL** (Static Inspection: Dashboard displays live state via 3-second polling; operational shift checklist required).

Part 5 — Roles and Enforcement

- **Policy Approver:** IT Department Head.
- **Technical Implementer:** MIS Staff (Key Custodian).
- **Awareness & Communication:** The IT Department Head must distribute key custody guidelines to all teaching faculty at the start of each semester.
- **Compliance Monitoring:** MIS Staff must monitor live key statuses during class transitions.
- **Violation Handling:** Suspected key retention violations or unregistered transfers must be documented and referred to the IT Department Head for review under applicable university policies. Any disciplinary action must follow established institutional procedures.
- **Exceptions:** Emergency laboratory access by campus security or fire personnel during crises is exempt from web pre-authorization, subject to post-incident manual logging.

POLICY 4: IOT DEVICE SECURITY, NETWORK PROTECTION, AND SECURITY EVENT HANDLING

Policy Specification Parameter	Policy Details
Policy Title	IoT Device Security, Network Protection, and Security Event Handling Policy
Policy Version	Version 1.3 (Academic Submission)
Proposed Effectivity Date	November 1, 2026 (Subject to institutional approval)
Policy Owner	MIS Technical Staff / Embedded Lead (Proposed Role, Subject to Approval)
Approving Role	IT Department Head
Target Components	`middleware/iotAuth.js`, `routes/iot.routes.js`, `LabSync_ESP32/LabSync_ESP32.ino`, database table `iot_devices`
Addressed Risks	**R1** (Insecure TLS), **R13** (Wi-Fi Credential Exposure), **R14** (NVS Alert Queue Buffer Limit)

Part 1 — Policy Identity and Purpose

The purpose of this policy is to safeguard communication between physical ESP32 key boxes and the cloud backend against eavesdropping, token theft, and status falsification, mandate cryptographic device authentication, eliminate hardcoded network secrets from version control, and enforce power-cycle incident resilience. This policy aligns with **NIST CSF 2.0** functions *PROTECT (PR.DS-02, PR.AA-01)* and *DETECT (DE.CM-01)*.

Part 2 — Scope and Context

- **System Components Covered:** ESP32 firmware compilation, Bearer token authentication, SHA-256 device hashing, room authorization validation, telemetry heartbeats, Wi-Fi reconnection loops, and FreeRTOS task scheduling in `middleware/iotAuth.js`, `routes/iot.routes.js`, and `LabSync_ESP32.ino`.
- **Users and Roles Covered:** Embedded Hardware Developers, Network Administrators, MIS Staff, and physical ESP32 microcontrollers.
- **Information Covered:** IoT Device Bearer tokens, token hashes, hardware MAC addresses, Wi-Fi network credentials, telemetry heartbeat JSON payloads, and ADC sensor readings.
- **Exclusions & Assumptions:** Applies to microcontrollers deployed in IT laboratories; does not govern client browser connections. Assumes microcontrollers connect via campus Wi-Fi infrastructure.

Part 3 — Risk Basis

1. **Risk R1 — Microcontroller Telemetry Interception via Insecure TLS:**
   - *Asset:* Real-time key status events, authorization requests, and device bearer tokens.
   - *Threat:* Man-in-the-Middle (MitM) interception on the local campus network.
   - *Weakness:* `LabSync_ESP32.ino` calls `client.setInsecure()` across lines 1045, 1093, 1146, and 1241.
   - *Consequence:* An attacker can spoof "Key Returned" events while keys are stolen or extract device tokens.
   - *Existing Safeguards:* Server checks SHA-256 token hash; NVS flash incident latching.
   - *Ratings:* Likelihood = Medium, Impact = High, Priority = **HIGH**.
   - *Rating Rationale:* Disabling certificate validation allows simple ARP poisoning tools to intercept HTTPS traffic.
   - *Linked Clauses:* Clause 4.1.

2. Risk R13 — Version Control Exposure of Campus Laboratory Wi-Fi Credentials:

- *Asset:* Campus Laboratory Wi-Fi network security and subnet isolation.
- *Threat:* Unauthorized network access via credentials committed to shared/public repositories.
- *Weakness:* `LabSync_ESP32.ino:33-34` hardcodes the Wi-Fi `ssid` and `password` in a tracked Git file across commit history.
- *Consequence:* Unauthorized individuals obtain local laboratory network credentials from repository history.
- *Existing Safeguards:* `secrets.h` used for device token; `.env` excluded from version control via `.gitignore`.
- *Ratings:* Likelihood = Medium, Impact = Medium, Priority = **MEDIUM**.
- *Rating Rationale:* Committing plaintext Wi-Fi credentials creates an ongoing exposure if repository access expands.
- *Linked Clauses:* Clause 4.2.

3. Risk R14 — Microcontroller NVS Alert Queue Buffer Overflow During Extended Disconnection:

- *Asset:* Physical tamper alerts (`Unauthorized Removal`).
- *Threat:* Offline alert buffer overflow during prolonged power or network outages.
- *Weakness:* ESP32 NVS persistent queue capacity is bounded to 16 alerts (12 persistent + 4 overflow) in flash memory.
- *Consequence:* If more than 16 alert events occur during an extended offline period, older un-synced alerts may be lost.
- *Existing Safeguards:* Non-volatile storage (`Preferences.h`) persistence across reboots for up to 16 events.
- *Ratings:* Likelihood = Low, Impact = Medium, Priority = **LOW**.
- *Rating Rationale:* Verified locally via `tests/test-firmware-power-cycle-security.js` Scenarios 15 & 16; buffer overflow requires prolonged outage combined with repeated tampering.
- *Linked Clauses:* Clause 4.4.

Part 4 — Mandatory Policy Clauses

1. **Clause 4.1 — Mandatory Transport Layer Security & Certificate Validation:** Microcontroller firmware transmitting telemetry over HTTPS must validate the server's X.509 certificate against an embedded Root CA certificate (ISRG Root X1). The use of `client.setInsecure()` is strictly prohibited in production firmware builds. Firmware compilation scripts must inject the CA certificate header prior to binary deployment.
   Implementation Status: **MISSING / NOT IMPLEMENTED** (Static Inspection: Currently calls `client.setInsecure()` at lines 1045, 1093, 1146, 1241 in `LabSync_ESP32.ino` ; requires remediation).
2. **Clause 4.2 — Firmware Credential Segregation Standard:** Microcontroller network and device credentials must be loaded via local secrets header files (e.g., `LabSync_ESP32/secrets.h`) that are strictly excluded from version control via `.gitignore`. Hardcoding Wi-Fi SSIDs, passwords, or tokens in tracked firmware source files is prohibited. Previously committed credentials must be treated as compromised; the physical router password must be rotated and Git commit history sanitized.
   Implementation Status: **PARTIALLY IMPLEMENTED** (Static Inspection: Device token externalized to `secrets.h` ; Wi-Fi credentials hardcoded at lines 33–34 require remediation).
3. **Clause 4.3 — Cryptographic Device Authentication & Room Scoping:** Every deployed microcontroller must authenticate via an `Authorization: Bearer` HTTP header. The backend (`middleware/iotAuth.js`) must hash incoming tokens with SHA-256 and match them against `iot_devices.Token_Hash`. The server must verify that the requested room exists in `iot_devices.Authorized_Rooms`. Requests targeting unauthorized rooms must be rejected with HTTP 403, and the security incident recorded in `audit_logs`.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `middleware/iotAuth.js:37-41, 93-103` ; `services/iot/occupancy.service.js:47-61` ; `database/migrations/010_create_iot_devices.sql`).
4. **Clause 4.4 — Power-Cycle Incident Persistence (NVS Flash Latching):** Security incidents (unauthorized removals, wrong-slot insertions) and pending offline alerts must be latched in Non-Volatile Storage (NVS) flash memory using under the `"labsync_sec"` namespace. Upon boot, firmware must inspect flash storage, immediately restore alarm states, and transmit queued events (up to the 16-event queue limit) once Wi-Fi connects.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `LabSync_ESP32.ino:42-56, 1936-2008` ; Test Executed: `tests/test-firmware-power-cycle-security.js`).
5. **Clause 4.5 — Elimination of Unauthenticated Development Fallbacks:** In all staging and production environments, `ENFORCE_IOT_AUTH = true` must be enforced. Development fallback branches in `middleware/iotAuth.js:42-57` that accept unauthenticated payloads based on plain `deviceId` strings must be permanently disabled.
   Implementation Status: **PROPOSED POLICY CONTROL** (Static Inspection: Currently permits unauthenticated fallback when `IS_PRODUCTION` is false in `middleware/iotAuth.js:42-57`).
6. **Clause 4.6 — Telemetry Heartbeat & Dead-Man Monitoring:** Microcontrollers must transmit an authenticated heartbeat (`/api/occupancy/heartbeat`) every 15 seconds. If the backend fails to receive a heartbeat for more than **60 seconds** (`OFFLINE_THRESHOLD_MS = 60 * 1000`), the system must flag the key dock as "OFFLINE", prompting physical inspection by MIS Staff.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `LabSync_ESP32.ino:1139-1221` ; `services/iot/iot.config.js:8` ; `services/iot/device-state.service.js:52-56` ; `tests/test-iot-heartbeat-inactivity.js:26`).

Part 5 — Roles and Enforcement

- **Policy Approver:** IT Department Head.
- **Technical Implementer:** MIS Technical Staff / Embedded Lead (Proposed Role, Subject to Approval).
- **Awareness & Communication:** Firmware developers must receive training on credential segregation and secure flashing practices.
- **Compliance Monitoring:** MIS Staff must review device `Last_Seen` timestamps daily to identify disconnected hardware.
- **Violation Handling:** Suspected device tampering or packet forgery must be documented and referred to the IT Department Head for review under applicable university policies. Compromised device tokens must be immediately revoked (`Is_Active = 0`) in `iot_devices`.
- **Exceptions:** Temporary use of USB-serial logging for firmware debugging is permitted in the development lab but strictly prohibited on units deployed in classrooms.

POLICY 5: BACKUP, RECOVERY, EXTERNAL NOTIFICATIONS, AND LOG MANAGEMENT

Policy Specification Parameter	Policy Details
Policy Title	Backup, Recovery, External Notifications, and Log Management Policy
Policy Version	Version 1.3 (Academic Submission)
Proposed Effectivity Date	November 1, 2026 (Subject to institutional approval)
Policy Owner	MIS Staff / System Administrator
Approving Role	IT Department Head
Target Components	`database/`, `services/activityRetentionService.js`, `server.js`, `config/app.config.js`, `services/email/email.transport.js`
Addressed Risks	**R2** (Missing Backups), **R10** (Email Webhook Failure), **R15** (Database Storage Bloat & Audit Log Accumulation)

Part 1 — Policy Identity and Purpose

The purpose of this policy is to establish robust operational baselines governing runtime secret configuration, production error suppression, automated historical data pruning, scheduled logical database backups, and verifiable disaster recovery procedures to prevent catastrophic data loss. This policy aligns with **NIST CSF 2.0** functions *RECOVER (RC.RP-01)*, *PROTECT (PR.DS-11)*, and *GOVERN (GV.PO-01)*.

Part 2 — Scope and Context

- **System Components Covered:** Environment variable injection, centralized error handling, Google Apps Script webhook relay, MySQL connection pooling, database migrations, physical log pruning, and database dumps within `database/`, `services/activityRetentionService.js`, `server.js`, and `config/app.config.js`.
- **Users and Roles Covered:** Database Administrators, DevOps/Hosting Engineers, and MIS Staff.
- **Information Covered:** MySQL schemas, `.env` configuration files, database credentials, session secrets, `occupancy_log` archives, and `audit_logs`.
- **Exclusions & Assumptions:** Covers application and database operational continuity; does not cover physical building utilities (campus electrical power grid). Assumes hosting on containerized cloud infrastructure (Railway). The application repository contains no automated logical backup scripts; actual Railway backup availability, eligibility, and enablement must be confirmed directly in the active project dashboard.

Part 3 — Risk Basis

1. Risk R2 — Catastrophic Data Loss Due to Missing Application Backup Mechanisms:

- *Asset:* Entire MySQL relational database (all tables managed by migration scripts).
- *Threat:* Cloud volume corruption, hosting termination, or accidental database dropping.
- *Weakness:* The application repository contains zero automated logical backup scripts; actual Railway cloud volume backup availability, eligibility, and enablement must be confirmed in the active project dashboard.
- *Consequence:* Total and permanent loss of academic laboratory records and key accountability logs.
- *Existing Safeguards:* MySQL2 pooled connection handling; non-destructive deactivation for administrative accounts.
- *Ratings:* Likelihood = High, Impact = High, Priority = **CRITICAL**.
- *Rating Rationale:* Operating a production academic system without verified backups is an unacceptable single point of failure.
- *Linked Clauses:* Clause 5.4, Clause 5.5.

2. Risk R10 — Transactional Email Relay Failure via Quota Exhaustion:

- *Asset:* Password recovery tokens and faculty key notification dispatches.
- *Threat:* Gmail daily quota exhaustion or execution timeout on the Google Apps Script Web App relay.
- *Weakness:* Unverified external configuration on Google Apps Script infrastructure.
- *Consequence:* Faculty and staff locked out during password recovery due to undelivered reset links; critical security notices fail to dispatch.
- *Existing Safeguards:* 12-second HTTP abort timeout; rate limiting on password recovery requests.
- *Ratings:* Likelihood = Low, Impact = Medium, Priority = **LOW**.
- *Rating Rationale:* Modest academic email volume makes quota hits infrequent, but delivery failure directly blocks self-service account recovery and delays incident alerting.
- *Linked Clauses:* Clause 5.3.

3. Risk R15 — Database Storage Growth & Query Degradation via Unpruned Audit Logs:

- *Asset:* MySQL storage volume capacity and query index performance.
- *Threat:* Gradual accumulation of audit event logs over multi-year operational lifecycles.
- *Weakness:* Microcontroller telemetry heartbeats do not create rows (they mutate `laboratories.Last_Seen` in-place). However, while `occupancy_log` is actively protected by automated daily 1-year pruning, `audit_logs` has no automated pruning or archiving mechanism in application code and is not technically immutable or append-only.
- *Consequence:* Long-term query degradation in audit trail retrieval and container storage bloat over extended multi-year operation.
- *Existing Safeguards:* Heartbeats update in-place without row creation; automated daily 1-year cutoff pruning via indexed SQL deletion for `occupancy_log` (`services/activityRetentionService.js:22-90`).
- *Ratings:* Likelihood = Low, Impact = Low, Priority = **LOW**.
- *Rating Rationale:* Heartbeats do not expand database rows. Active 1-year pruning prevents `occupancy_log` bloat; `audit_logs` growth is bounded by relatively low administrative and security event volumes.
- *Linked Clauses:* Clause 5.2.

Part 4 — Mandatory Policy Clauses

1. **Clause 5.1 — Strict Secret Segregation & Version Control Hygiene:** Backend credentials (database passwords, `SESSION_SECRET`, and `EMAIL_WEBHOOK_SECRET`) must be loaded strictly through protected runtime environment variables. All production configuration files (`.env`) must remain in `.gitignore`. Production startup must halt immediately via `validateProductionConfig()` (`server.js:31`; `config/app.config.js:83-85`) if required secrets are missing or default placeholders, ensuring default secrets cannot be used by web sessions or student verification HMAC tokens in production.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `server.js:31, 40-42`; `.gitignore:1-15`; `config/app.config.js:40-60, 83-85`).
2. **Clause 5.2 — Automated Physical Log Retention & 1-Year Pruning:** Physical room occupancy and key event records in `occupancy_log` must be retained for exactly one calendar year to satisfy academic audit requirements. Records exceeding the 365-day cutoff must be pruned daily via indexed SQL deletion (`activityRetentionService.js`) without loading records into Node.js heap memory. Telemetry heartbeats execute in-place updates (`Last_Seen = NOW()`) without row growth. Automated pruning or archiving of `audit_logs` was not found in reviewed application code; periodic archiving of `audit_logs` is designated as a proposed governance control.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `services/activityRetentionService.js:22-90`; `services/iot/heartbeat.service.js:54`; `database/migrations/015_add_occupancy_log_access_time_index.sql`).
3. **Clause 5.3 — Transactional Email Webhook Security & Timeout Protection:** Outbound email dispatches via the Google Apps Script webhook relay must enforce HTTPS transmission, a 12-second abort timeout (`timeoutMs = 12000`), and shared secret authentication (`EMAIL_WEBHOOK_SECRET`) passed in both headers and JSON payload. Live receiver-side script properties must be verified annually on `script.google.com`. Failure of email relay suppresses self-service password recovery and critical security dispatches.
   Implementation Status: **PARTIALLY IMPLEMENTED** (Static Inspection: Backend sending verified in `services/email/email.transport.js:100-138`; Google Apps Script receiver property configuration is an unverified external setting).
4. **Clause 5.4 — Mandatory Logical Database Backup Schedule:** To resolve the absence of application backup code in the reviewed repository, the database administrator must configure a scheduled daily logical backup (`mysqldump`) of all MySQL database tables. Backup archives must be encrypted with AES-256 and transmitted offsite to secure institutional storage (BulSU Google Drive; Target RPO ≤ 24 hours, RTO ≤ 2 hours). Actual Railway cloud volume backup availability, eligibility, and enablement must be confirmed in the active project dashboard. Automated offsite logical backups remain a proposed control until demonstrably implemented.
   Implementation Status: **MISSING / NOT IMPLEMENTED** (Static Inspection: The application repository contains zero automated logical backup scripts; live Railway volume backup availability must be confirmed in the project dashboard; automated offsite backups are proposed).
5. **Clause 5.5 — Semesterly Disaster Recovery Restoration Simulation:** The MIS technical team must execute a documented disaster recovery simulation once per academic semester. The test must restore the most recent logical backup archive to an isolated staging database and verify row-count parity across users, keys, schedules, and maintenance records. This procedure is a proposed policy requirement and has not yet been conducted on live systems.
   Implementation Status: **PROPOSED POLICY CONTROL** (Requires formal adoption in MIS semester operational calendar).
6. **Clause 5.6 — Safe Production Error Suppression:** Centralized error handling middleware (`middleware/errorHandler.js`) must suppress raw database errors, SQL syntax strings, and server stack traces in production environments, returning generic HTTP 500 JSON responses (`"Internal server error"`) to prevent reconnaissance.
   Implementation Status: **IMPLEMENTED — EVIDENCE VERIFIED** (Static Inspection: `middleware/errorHandler.js:15-35`).

Part 5 — Roles and Enforcement

- **Policy Approver:** IT Department Head.
- **Technical Implementer:** MIS Staff / System Administrator.
- **Awareness & Communication:** Development team members must review the `.gitignore` policy prior to receiving Git commit access.
- **Compliance Monitoring:** MIS Staff must inspect daily backup execution logs and storage quotas once implemented.
- **Violation Handling:** Suspected configuration compromises or accidental credential commits must be documented and referred to the IT Department Head for review under applicable university policies. Exposed credentials must be rotated immediately.
- **Exceptions:** Emergency manual database schema adjustments during outages must be executed within transactional wrappers and backfilled into sequential migration files within 24 hours.